Removal Sample Audit: פרק הארכיטקטורה · Case 03

לפי פרק 3 (ארכיטקטורה) בתבנית תיק הפרויקט של מגשימים: המישורים, הרכיבים, ההודעות ביניהם, תרחיש בתנועה, מה קורה כשרכיב נופל, ההחלטות, סדר הבנייה ומה נשמר. הדמויות בדויות.

הקדמה

באפיון תיארנו חלקים: הקפאה, הגרלה, שכבות, אפליקציה, שיבוץ, אומדן. אבל רעיון לא רץ על שום מחשב.

עכשיו השאלה של מי שבונה: אילו תוכנות יש, איפה כל אחת יושבת, ומי מחזיק אותה?

ובביקורת, "מי מחזיק" היא לא שאלת אחסון. היא השאלה כולה.

המישורים (מגרשים)

מגרש	מה רץ בו
מגרש יחידת הביקורת	הקפאה, הגרלה, דוגם, חישוב ודוח.
מגרש השטח	האפליקציה במכשירי הבודקים, וסנכרון.
מגרש הציבור	הדוח, חבילת השחזור וה-beacon.
מאגר הבודקים ?	גיוס, אימון, תשלום ואימות עצמאות. לא הוגדר מי מחזיק.

הרכיבים

יצוא הוועדה (**ECI export**)

מגרש:

רשימת המחיקות של המחוז, מהמערכת של ועדת הבחירות.

- נכנס:
- יוצא:
- אף פעם לא: ניתן להחלפה רק ברשימה רשמית אחרת.

הקפאה (**Freezer**)

מגרש: מגרש יחידת הביקורת · טכנולוגיה: SHA-256

נועל את הרשימה ומפרסם גיבוב.

- נכנס: קובץ מחיקות.
- יוצא: רשימה נעולה וגיבוב.
- אף פעם לא: לא משנה שורה אחרי ההקפאה.

Beacon ציבורי (**NIST Beacon**)

מגרש:

פעימה אקראית ציבורית.

- נכנס:
- יוצא:
- אף פעם לא: ניתן להחלפה ב-drand.

הדוגם (**Sampler**)

מגרש: מגרש יחידת הביקורת · טכנולוגיה: Python

גוזר seed ובוחר 1,500 פריטים לפי שכבות.

- נכנס: רשימה נעולה ופעימה.
- יוצא: רשימת ביקורים.
- אף פעם לא: לא בוחר ביד.

השיבוץ (**Assignment**)

מגרש: מגרש יחידת הביקורת · טכנולוגיה: PostgreSQL

משבץ בודקים לפי כללי ניגוד עניינים, ו-10% ביקורים כפולים.

- נכנס: ביקורים ומאגר.
- יוצא: רשימה לכל בודק.
- אף פעם לא: לא משבץ בודק במחוז או בקלפי שלו.

מאגר הבודקים (**Verifier pool**)

מגרש: ? מאגר הבודקים

מי שדופק בדלת. האפיון מניח שהוא עצמאי, ולא קובע מי מגייס ומשלם.

- נכנס: ?
- יוצא: בודקים זמינים.
- אף פעם לא: ?

אפליקציית השטח (**Field app**)

מגרש: מגרש השטח · טכנולוגיה: PWA, WebAuthn, IndexedDB

PWA לא מקוונת. ממצא חתום בכל כתובת.

- נכנס: רשימת כתובות.
- יוצא: ממצאים חתומים.
- אף פעם לא: לא שולחת ממצא בלי חתימה.

סנכרון (**Sync**)

מגרש: מגרש השטח · טכנולוגיה: HTTPS

מעלה ממצאים כשיש קליטה.

- נכנס: ממצאים מהמכשיר.
- יוצא: ממצאים לשרת.
- אף פעם לא: לא מוחק ממצא מהמכשיר לפני אישור.

מאגר הממצאים (**Findings store**)

מגרש: מגרש יחידת הביקורת · טכנולוגיה: PostgreSQL

ממצאים בלי שמות, כתובות מוצפנות. שנתיים.

- נכנס: ממצאים.
- יוצא: ממצאים לחישוב.
- אף פעם לא: אין בו שמות.

החישוב (**Estimator**)

מגרש: מגרש יחידת הביקורת · טכנולוגיה: SciPy

Wilson, Rogan-Gladen ו-SPRT.

- נכנס: ממצאים.
- יוצא: אומדן, טווח, קלפיות.
- אף פעם לא: לא מפרסם בלי טווח.

הדוח (Report)

מגרש: מגרש הציבור · טכנולוגיה: HTML

אומדן, טווח, קלפיות והחלטה.

- נכנס: מהחישוב.
- יוצא: דוח פומבי.
- אף פעם לא: לא מפרסם מספר בלי שיטה.

חבילת השחזור (Repro pack)

מגרש: מגרש הציבור · טכנולוגיה: ZIP

כל מה שצריך כדי להריץ ולקבל אותו מספר.

- נכנס: מכל הרכיבים.
- יוצא: קובץ פומבי.
- אף פעם לא: אין בו שמות.

ההודעות בין הרכיבים

RemovalFrame

מהוועדה אל ההקפאה

```
{ "district": 131, "count": 480000, "rows_sha256": "9f2c..." }
```

שדה	סוג	משמעות
`rows_sha256`	32 בתים	הגיבוב.

SampleItem

מהדוגם אל השיבוץ

```
{ "frame_row": 77812, "stratum": "absent/shifted/other", "booth": 212 }
```

שדה	סוג	משמעות
`stratum`	טקסט	שכבה.

Finding

מהאפליקציה אל הסנכרון

```
{ "item_id": 77812, "outcome": "LIVES_HERE", "gps_hash": "a1...", "device_sig": "..." }
```

שדה	סוג	משמעות
`device_sig`	חתימה	מי ומאיפה.

Verifier

מהמאגר אל השיבוץ

```
{ "verifier_id": "?", "registered_district": "?", "employer": "?" }
```

שדה	סוג	משמעות
employer	?	מי משלם לבודק.

תרחיש בתנועה: מחוז אחד

מחוז 131, 480,000 מחיקות. נעקוב עד ההחלטה.

- הוועדה מייצאת את הרשימה.
- נעולה, גיבוב 9f2c… מתפרסם.
- פעימת NIST של 10:01.
- 1,500 ביקורים, רובם לסל.
- בודקים מהמאגר.
- כללי ניגוד עניינים, 10% כפולים.
- כתובות לטלפונים.
- מינה פתחה בביקור השלישי.
- ממצאים לשרת.
- 12.2% [10.4, 14.19].
- לדוח.
- מעל 5%: בדיקה מלאה.

תרחיש בתנועה: בודקים מהמנגנון

המאגר הוא בעצם עובדי הוועדה.

- אין מאגר עצמאי. הוועדה שולחת את אנשיה.
- הם משובצים, במחוז אחר.
- הם מאשרים 70% מהמחיקות השגויות.
- 3.5% [2.3, 4.9]. טווח צר ומשכנע.
- מתחת לסף. אין בדיקה מלאה.

תרחיש בתנועה: דלתות סגורות

20% מהדלתות לא נפתחות.

- NO_ANSWER.
- ביקור שני ושלישי.
- UNKNOWN נכנס כטווח.
- הטווח רחב יותר, לא מוטה.

תרחיש בתנועה: כפר בלי קליטה

אין קליטה יומיים.

- ממצאים נשמרים בטלפון, חתומים.
- כשיש קליטה.
- סנכרון.

תרחיש בתנועה: רשימה שהוחלפה

מישהו מחליף את הרשימה אחרי ההגרלה.

- גיבוב אחר.
- לא מתאים למה שפורסם. עצירה.

מה קורה כשרכיב נופל

רכיב שנופל	מה קורה
הקפאה	אין הקפאה, אין הגרלה.
הדוגם	ה-seed פומבי, אפשר להריץ שוב בכל מחשב.
השיבוץ	אין שיבוצים חדשים. בודקים עם רשימה ממשיכים.
מאגר הבודקים	אין מי שילך לדלת. ואם הוועדה שולחת את אנשיה, אין שום רכיב שרואה את ההבדל.
אפליקציית השטח	ממצאים שמורים בטלפון.
סנכרון	ממצאים מחכים בטלפונים.
מאגר הממצאים	עותק שני.
החישוב	החישוב מתוקנן, אפשר להריץ שוב.
הדוח	החבילה מתפרסמת בכל מקרה.
חבילת השחזור	הדוח מתפרסם, החבילה אחריו.
יצוא הוועדה	אין רשימה, אין ביקורת.
Beacon ציבורי	drand כגיבוי, ונרשם.

ההחלטות

1. מדגם או ספירה מלאה?

- ספירה מלאה: אמת מלאה. שנה של עבודה.
- מדגם של 1,500: תשובה על המחוז, בשבועות.

בחרנו מדגם. זמן: הפנקס הסופי לא מחכה שנה. המחיר: תשובה על המחוז, לא על פריה.

2. פומבי **seed**?

- קבוע: פשוט.
- פומבי, אחרי ההקפאה: אף אחד.

בחרנו פומבי. seed קבוע ידוע למי שכתב אותו. המחיר: תלות במקור חיצוני.

3. דלת סגורה?

- "עבר": זול.
- שלושה ביקורים, ואז טווח: לא מאשר טעות.

בחרנו שלושה ביקורים. "לא בבית" הוא הטעות עצמה. המחיר: עוד ביקורים.

4. מי דופק בדלת?

- עובדי הוועדה: יש להם כוח אדם בכל מקום.
- מאגר עצמאי: עצמאי. אבל מי מקים?

בחרנו מאגר עצמאי, ואין מי שיקים אותו. מעבדה 4: עובדי הוועדה נותנים 3.5% במקום 12.2%. המחיר: שאלה פתוחה, שמפילה את הפרויקט.

סדר הבנייה

ספרינט	המטרה	מבחן היציאה
ספרינט 1: הקפאה והגרלה	רשימה נעולה, seed פומבי, מדגם.	כל אחד משחזר את המדגם.
ספרינט 2: חישוב וחבילה	Wilson, תיקון, חבילה.	12.2% מנתוני POC.
ספרינט 3: אפליקציה	PWA לא מקוונת, חתימה.	ממצא חתום מכפר בלי קליטה.
ספרינט 4: שיבוץ	כללי ניגוד עניינים, ביקורים כפולים.	בודק לא משובץ בקלפי שלו.
ספרינט 5: דוח	דוח וסף.	מחוז 131 נשלח לבדיקה מלאה.

איפה יושב כל חלק מהאפיון

#	חלק	רכיבים	הערה
1	הקפאה	יצוא הוועדה, הקפאה	לפני הפעימה.
2	הגרלה	ציבורי, הדוגם Beacon	הפעימה אחרי ההקפאה.
3	שכבות	הדוגם	בתוך הדוגם.
4	אפליקציה	אפליקציית השטח, סנכרון	במכשיר, לא בשרת.
5	ביקור חוזר	השיבוץ, אפליקציית השטח	השיבוץ יוצר סבב.
6	שיבוץ	השיבוץ, מאגר הבודקים	והמאגר?
7	אומדן	החישוב, מאגר הממצאים	ב-SciPy.
8	קלפיות	החישוב	SPRT.
9	דוח	הדוח	עם החלטה.
10	חבילה	חבילת השחזור	בלי שמות.

מה נשמר, ואיפה

עובר ולא נשמר:

- **RemovalFrame**: הרשימה, עד שננעלה.
- **SampleItem**: הפריט עד השיבוץ.

נשמר:

- בארון (שנתיים): ממצאים חתומים בלי שמות; כתובות מוצפנות.
- בציבור (לתמיד): גיבוב, פעימה, דוח וחבילה.

בדיקה אחרונה: האם הכול סגור?

מבט אחרון: האם המערכת יכולה לקיים את ההבטחה המרכזית שלה, מספר אמין לכל מחוז, רק עם רכיבים שבתוך הגבולות שלה?

שלושה רכיבים בחוץ. לשניים יש תחליף: היצוא והפעימה. לשלישי, מאגר הבודקים, אין. והוא בדיוק הקלט שכל מספר נשען עליו: האמת בשטח.

המעגל לא סגור. רכיב חיוני מחוץ לגבולות, ואין מי שיביא אותו.